

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
March 2026	Data Protection	OT002.P	Livia Li	Updated testing references
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
April 2025	All	All	Livia Li	Updated links and applicable testing, removed Business Continuity Planning section
April 2024	Planning	Self-Service Report and Fraud Template	Jessica Lin	Added Self-Service Report (WWBCIT), updated links and proper nouns
April 2023	Data Protection	OT002.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	5
PLANNING: Data Analysis.....	6
PLANNING: Reference Material	7
PLANNING: Self-Service Report	8
PLANNING: Fraud Template.....	9
CONTROL ASSESSMENT QUESTIONS	10
Key Control Question: 1. Recruitment.....	10
Primary Test: Source Candidates for Requisitions, Screen and Select Applicants, and Manage Offers (ON001.P).....	12
Primary Test: Manage Offer Acceptance and Post Offer Employment Verification Standards (ON002.P).....	14
Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes	15
Primary Test: Compliance with Laws and Regulations (OT001.P)	16
Primary Test: Data Protection (OT002.P).....	17

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PROCESS AND OBJECTIVE

Process Definition:

The Talent Acquisition (TA) is a sub-process within the human resources (HR) function. It encompasses the design and execution of programs, and the process needed to attract and select employees for IBM.

Note: Executive Search & Integration (ES&I) is an IBM in-house executive search practice. ES&I proactively identifies, engages, assesses, and recruits top executive talent within our industry's landscape and beyond.

Process Strategic Objective:

There are five Strategic Imperatives:

1. Be Integral to Client Success
2. Rethink Selection and Assessment
3. Diverse and Inclusive Hiring
4. Deploy TA Tech Stack
5. Integrated Agile Delivery

There are five Principles:

Underlying the Talent Acquisition strategy are the principles by which we operate.

1. Personalized Experiences
2. Data Driven Decisions
3. Transparency
4. Shared Accountability
5. Collaboration

Control Assessment Questions:

When auditing the process evaluate and test risks for Recruiting and hiring (40-30-00).

Control Assessment Topics:

- Sourcing, Selection and Offering: including sourcing candidates and managing requisitions, reviewing applications, interviewing candidates, and making offers.
- [Global Employment Verification Standards \(GEVS\)](#): Verify the 9 GEVS checks. Be aware that requirements could vary according to laws and regulations.
- Laws and regulations: Verify compliance with country-specific requirements if applicable.
- Data privacy: including how Personal Information (PI) and Sensitive Personal Information (SPI) is handled among or between IBM organizations and third-party vendors involved.

Note: For executive hires there are 9 GEVS and 3 Exec specific checks applicable.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PROCESS AND OBJECTIVE (Continued)

Other Tests:

Be mindful of the following:

Protection of sensitive personal information (SPI) is critically important and is required by law in many places around the world. Review the following, noting how each is periodically validated and reported:

- Separation of duties: assess roles, tasks, and access to applications to understand what employees can do with the roles and tasks assigned, in conjunction with the access to applications and data they have been granted.
- Access to data and applications: review the following elements of access management
 1. Granting access
 2. Periodically reviewing access
 3. Revoking access

HR work may be performed by IBM regular employees and subcontractors. Where work is performed by subcontractors, review the [IT Security Standard](#) for compliance.

Note: The work in the ES&I organization is not performed by subcontractors only by IBM regular or employees.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PLANNING: Audit Program Risk Alignment

Global Talent Acquisition

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Source Candidates, Screen and Select, Manage Offer, Manage On-Boarding	High	Recruitment	ON001.P, ON002.P
Data Privacy and Protection	High	Other: Use for all Aspects of HR Primary and Business Processes	OT001.P, OT002.P
Vendor/Agency Management	Medium	Recruitment	ON001.P
Sign-on Bonus	Medium	Recruitment	ON002.P
Employee Referral Bonus	Low	Recruitment	ON002.P

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

Validate the following match both in the Global Opportunity Marketplace (GOM) application and Operational Data Manager (ODM) or other HR systems as applicable: (The Technology team should be able to help with this).

- Salary
- Band
- Start Date
- Total records match for both GOM and ODM/HR systems, as applicable

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PLANNING: Reference Material

Use this link to all corporate directives, policies, and instructions:

[IBM Corporate Directives](#) - these can change over time:

Corporate Policies

- [117: Workforce Diversity](#)
- [130: IBM Data Privacy Policy](#)

Corporate Instructions and Guidelines

IT Security Standard (ITSS)

Enterprise Transformation (ET)

- [ET127: Business Continuity Management](#)

Finance

- [FIN 101: Control of Disbursements](#)
- [FIN 194: Intercompany Transactions Policy and Procedures](#)
- [FIN 151: Application Systems Control and Auditability \(ASCA\)](#)
- FIN 167: Vendor Sourced Labor Services (now owned by Global Procurement. See [PROC 167](#): Supplier sourced goods and services)

Legal

- [LEG 116: Classification and Control of IBM Information](#)
- [LEG 117: Internet Privacy - Personal Information Collected On-Line](#)

Human Resources, especially

- [HR 113: Protection of Employee Information](#)
- [HR 114: IBM Global Employment Standards](#)

Other

Data Privacy/Protection, Regulations, and Compliance

- IBM Guidelines for the Protection of Employee Information
- Guidance on Personal Information (PI) and Sensitive Personal Information (SPI)
- Privacy Impact Assessment (PIA)
- Global Process Owner's process requirements, documentation, and guidance
- Process requirements at a region, country, or local level
- Laws and regulations addressing topics such as:
 - o data privacy
 - o benefits: funding, aged claims, denied claims appeals
 - o taxability
 - o compensation
 - o recruiting (such as candidate selection) and hiring (for example, export regulations)
 - o visa and work permits
- [Recruiting@IBM](#)

Corporate Guideline for Business Process/Area Business Continuity Planning ([BPBC127 Guideline](#))

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
• Management Self-Assessment of Controls (MSAC) • Risk Evaluations (RE's) • Proactive Business Control Reviews • (No key controls)	WorldWide Business Controls Integrated Toolset (WWBCIT) is being replaced by Finance Business Controls OpenPages in 1Q 2025. For the data prior to 1Q 2025: Option 1: Login to WWBCIT. In the left side menu, select "Manage self assessment," "Risk evaluations," or "Proactive process review," and then select the applicable criteria to get the results. Option 2: Login to WWBCIT Cognos reports • Select "BCIT406 – Management Self Assessment Trending Report" or • Select "BCIT211 – Risk Evaluation Report" or • Select "BCITLL – Lessons Learned Detail Report," and then select the applicable criteria to get the results. For the data starting from 1Q 2025: Login to OpenPages, change the profile to "FBC General User". • Select the applicable process from the primary menu on the top left for all process related materials. • On the home page, select the report and export it with applicable criteria. Note: Reported (global) process: Global Talent Acquisition; Controllable Unit SubCategory: GTA

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Identity fraud resulting from incomplete or inaccurately performing the Proof of Identity (POI) check. Refer to GEVS (Global Employment Verification Standards) wiki.	Candidates must provide photographic proof of identity from an official government source (e.g., national id, driver's license, passport) prior to or on start date. Background check may be performed by IBM and /or an external vendor.	Obtain a compliance report showing POI results. If compliance achievement is less than 97%, select samples and request for evidence that case was investigated and closed, ensuring the candidate met requirements/guidelines set by IBM.
Misuse of IBM sign-on payments (SOP) offered to new hires.	Review candidates who received sign on payments ensuring that the payments were authorized appropriately.	Obtain a compliance report showing SOP results. If compliance achievement is less than 100%, select samples and request for evidence that case was investigated and closed, ensuring the approval requirements were met. Note: only applicable for amounts over USD \$50,001.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Recruitment

Objective:

Process Definition:

The Talent Acquisition (TA) is a sub-process within the human resources (HR) function. It encompasses the design and execution of programs, and the process needed to attract and select employees for IBM.

Note: Executive Search & Integration (ES&I) is an IBM in-house executive search practice. ES&I proactively identifies, engages, assesses, and recruits top executive talent within our industry's landscape and beyond.

Process Strategic Objective:

There are five Strategic Imperatives:

1. Be Integral to Client Success
2. Rethink Selection and Assessment
3. Diverse and Inclusive Hiring
4. Deploy TA Tech Stack
5. Integrated Agile Delivery

There are five Principles:

Underlying the Talent Acquisition strategy are the principles by which we operate.

1. Personalized Experiences
2. Data Driven Decisions
3. Transparency
4. Shared Accountability
5. Collaboration

Control Assessment Questions:

When auditing the process evaluate and test risks for Recruiting and hiring (40-30-00).

Control Assessment Topics:

- Sourcing, Selection and Offering: including sourcing candidates and managing requisitions, reviewing applications, interviewing candidates, and making offers.
- Global Employment Verification Standards (GEVS): Verify the 9 mandatory GEVS checks. Be aware that requirements could vary according to laws and regulations.
- Laws and regulations: Verify compliance with country-specific requirements if applicable.
- Data privacy: including how Personal Information (PI) and Sensitive Personal Information (SPI) is handled among or between IBM organizations and third-party vendors involved.

Note: For executive hires there are 9 GEVS and 3 Exec specific checks applicable.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Recruitment

(Continued)

Other Tests:

Be mindful of the following:

Protection of sensitive personal information (SPI) is critically important and is required by law in many places around the world. Review the following, noting how each is periodically validated and reported:

- Separation of duties: assess roles, tasks, and access to applications to understand what employees can do with the roles and tasks assigned, in conjunction with the access to applications and data they have been granted.
- Access to data and applications: review the following elements of access management:
 - Granting access
 - Periodically reviewing access
 - Revoking access

HR work may be performed by IBM regular employees and subcontractors. Where work is performed by subcontractors, review the [IT Security Standard](#) for compliance.

Note: The work in the ES&I organization is not performed by subcontractors only by IBM regular or employees.

Risk/Exposure:

See risks noted in each test.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Recruitment

Primary Test: Source Candidates for Requisitions, Screen and Select Applicants, and Manage Offers (ON001.P)

Objective:

There are five Strategic Imperatives:

1. Be Integral to Client Success
2. Rethink Selection and Assessment
3. Diverse and Inclusive Hiring
4. Deploy TA Tech Stack
5. Integrated Agile Delivery

There are five Principles:

Underlying the Talent Acquisition strategy are the principles by which we operate.

1. Personalized Experiences
2. Data Driven Decisions
3. Transparency
4. Shared Accountability
5. Collaboration

Risk or Exposure:

Failure to effectively manage recruiting and selection could result in suboptimal staffing choices that do not meet IBM's business needs.

Approach:

Review the process for recruiting and selecting candidates. Activities include an intake call/form to understand requirements, posting positions, where applicable, reviewing applications, screening candidates, interviewing candidates, and extending offers.

Expense could be incurred for applicants traveling to interviews. Include in the scope of the recruitment audit, if appropriate; Check that invoice validation is performed.

Review a sample of the monthly Global Recruitment Compliance Reports used for process oversight to validate that exceptions are either addressed or documented with explanations in a timely manner. There are seven global control points (GCPs) which are used to monitor and report on the Global TA process. These are used instead of Key Controls over Operations (KCOs) and Key Controls over Financial Reporting (KCFRs) and are listed as: (Request control point descriptions from client)

- Pre- and Post-offer Global Employment Verification (GEV) Checks (GCP 1 and GCP 2)
- Confirmation of Academic Achievement (GCP 3)
- Requisition to Offer Band Mismatch (GCP 4a)
- Sign-on Payment above USD50,001 Approval (GCP 4b)
- IBM Referral Program Payment Eligibility (GCP 6)
- Agency Approvals (GCP 8)

Note: There are seven control points which are used to monitor and report on the ES&I process.

- Pre and Post Executive Hire Specific Checks (GCP1 & GPC2c)
- Pre- and Post-offer Global Employment Verification (GEV) Checks (GCP 2a&b and GCP 3a&b)
- Global IBMer GEVS and Ready to Onboard (GCP 4)

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Recruitment

Primary Test: Source Candidates for Requisitions, Screen and Select Applicants, and Manage Offers (ON001.P)

(Continued)

For External hires, determine whether: (does not include Acquisition/Outsourcing)

1. Postings contained required language per laws and regulations (e.g., Equal Opportunity).
2. Criteria for screening, selection, and interviews were based solely on position requirements, and complied with laws and regulations.
3. Interview evaluation was available for offered candidates. If not, what action was taken?
4. Applicant travel expenses complied with IBM's travel policy, were properly reviewed, and submitted. Keep in mind that the responsibility for handling applicant travel expenses may be with a different organization.
5. Candidate information was complete and was reviewed as per process prior to determining whether to offer employment.
6. Sign-on payments above US\$50,001 were approved as defined by the global sign on approval matrix. If sign-on payments were offered, if repayment was relevant, was this included in the offer.
7. Offers complied with location salary matrixes or were approved accordingly. Obtain the approval matrix information for each country and each business line.
8. Test the process to ensure there is a recovery process where applicable for agency payments.

In addition to the global process owner's management system and monitoring of the global recruitment process, the systematic checks are as:

- S1-Systematic 1 labeled as Requisition Approval: Tool routes requisition to approver 1 and 2 for approval. System hard-stop prevents the process progressing until both approvals are completed
- S2-Systematic 2 - labeled as Offer Approval: Tool routes requisition to approver 1 and 2 for approval. System hard-stop prevents the process progressing until both approvals are completed.

Note: There are no clip levels for sign on bonuses, salary matrix or any other compensation pay elements for executives. Executive Compensation Team's approval is required prior to creating the offer letter.

- Systematic checks S1 and S2 not implemented
- Executive roles are not posted

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Recruitment

Primary Test: Manage Offer Acceptance and Post Offer Employment Verification Standards (ON002.P)

Objective:

There are five Strategic Imperatives and five Principles as prior stated:

Risk or Exposure: Failure to effectively manage hiring could result in suboptimal hiring choices that do not meet IBM's business needs.

Approach:

Review the process for handling each type of hire, including regular, fixed term/supplemental, student intern/ co-op, rehires, conversions where separations and recruitment was required.

Select samples of hires to determine:

1. Were required Global Employment Verification Standard checks completed as required?
2. If special payments (such as sign on payment) were made, how were conditions documented and agreed by line, accepted by the candidate, and proceeded according to the agreement? Approval requirements may vary. Evaluate whether agreements include repayment terms if appropriate, are appropriately approved, are signed by the candidate and are retained.
3. Obtain a universe of employee IBM Referral Program payments (IRP) for the audit period. This should include: Candidate name, candidate email ID, candidate TalentID, Referrer (IBMer) name, Referrer TalentID, bonus amount in local currency, bonus amount in USD.
4. Ensure that referral payments were administered according to the program guidelines.
5. Review IBM Referral Program Payment Eligibility (GCP 6) MLC results.

Note: IBM Referral Program is not applicable for ES&I. Hire type in scope: Regular, Supplemental/Fixed Term Hire and Rehire.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Objective:

IBM must fully comply with applicable laws and regulations. Determine whether process design and execution comply with laws and regulations. Risk or Exposure: Failure to comply with applicable laws and regulations may include fines or penalties.

Risk/Exposure:

Failure to comply with applicable laws and regulations could expose IBM to risk of litigation and harm IBM's image.

GLOBAL TALENT ACQUISITION

AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Compliance with Laws and Regulations (OT001.P)

Objective:

IBM must fully comply with applicable laws and regulations. Determine whether process design and execution comply with laws and regulations. Risk or Exposure: Failure to comply with applicable laws and regulations may include fines or penalties.

Risk or Exposure: Failure to comply with applicable laws and regulations could expose IBM to risk of litigation and harm IBM's image.

Approach:

Enquire with IBM Human Resources and Legal personnel to identify what laws and regulations could apply. Discuss how to apply this knowledge to the audit field work. Be prepared to review findings with Legal personnel if needed. Regulations could address topics such as:

- Data privacy and data protection.
- Whether personal information and sensitive personal information can be handled by third parties or handled by anyone outside the country.
- When it is or is not appropriate to share personal information and sensitive personal information.
- Requirements relevant to recruiting, hiring, export regulations, work permits, etc.
- Retaining records to confirm process execution.

During audit preparation and field work, keep this topic in mind for any scope area that is considered or is tested.

GLOBAL TALENT ACQUISITION

AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT002.P)

Objective:

This process involves access to and use of both Personal Information (PI) and Sensitive Personal Information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect PI and SPI.

Approach:

Consider ways that PI and SPI could be compromised. Test for the protection of PI and SPI information for anyone involved in performing process steps. This includes IBM employees, contractors, and vendors.

- Access to data and applications (including granting, periodic revalidating, and revoking)
- Separation of duties
- File transfers among IBM and vendors, including encryption and classification

Privacy and Data Protection requirements:

- Review the Privacy and Data protection requirements
- Was a Privacy Impact Assessment completed?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

GLOBAL TALENT ACQUISITION AUDIT PROGRAM #40-30-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT002.P)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of PIA for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education.

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education.

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.